

7.15 release Stack 04 — chain signing audit

First Copilot review and remediation, 2026-09-23

The owner's first authorized request was registered at 22:24:44 UTC. Review 5297522809 was delivered at 22:28:09 UTC on the exact edf76450b694f30bee21f7293ff3a74ec14b2c46 head and returned **Changes recommended**, with four inline findings. Three findings identify one missing contract at two call sites: exercise the actual handler, not only the shared pager. Commit 1fe4bc71c6882a88e6d40bcfc31a791844c123cf adds direct handler regressions. The MayaChain test accepts amount/recipient and rejects the long-denomination Asset screen, then checks ActionCancelled, aborted signing state, and exact confirmation consumption. The TRON test loads a wallet, builds raw transaction bytes for its derived owner with a 114-byte memo, accepts the transaction and prior memo pages, rejects the final page, then checks ActionCancelled, cleared derived-key scratch, and exact confirmation consumption. Both tests and the complete 435-test regular firmware suite pass locally. The fourth finding identified stale CI metadata; section 4 records the first reviewed head's completed run and artifact IDs. The remediation head bc57544cff4178d0ca46d6b14537750f4131b09a subsequently passed [exact-head CI run 35930492139](#). The owner's second authorized Copilot request was registered at 23:02:33 UTC. Review 5297798874 assessed bc57544c and returned **Changes recommended** with one low-severity report-metadata finding: this opening summary still described that now-completed CI run as pending. This report revision corrects that finding; the PR body and main audit ledger record the final documentation head and its CI separately.

1. Identity and frozen scope

- Owner: Codex /root, keepkey-vault-v11-agent-2. The claim and master ledger live in the **main firmware worktree** at docs/release/audit-claims/715-04/OWNER.md and docs/release/MASTER-AUDIT-TEMPLATE.md.
- Main master form SHA256 at intake: fd8669396fcebde1a04e40946b92465f95d8b3e56c03c93bf75424649a967d81.
- Isolated source worktree: /private/tmp/kk715-stack04-audit, branch audit/715-stack04-review.
- Code-bearing PR: [#834](#), release/715-stack-04-chain-signing against release/715-stack-03-recovery. Frozen predecessor 2e008f8527f663107922835dbc8761333b8f073f; intake head 9e6c56c267c6755f55364f2a48073880b4f6f6e4; source repair eeee19feb8d1961176b46e7e6e656be1c550c4e8; handler-test remediation 1fe4bc71c6882a88e6d40bcfc31a791844c123cf. The final containing report head belongs in the PR body after commit.
- Candidate is an internal release stack unit, not assembled release acceptance. Stack 03 predecessor audit acceptance, physical OLED/signing checks, final documentation-head CI, and external code review remain separate gates. Host/emulator signing flows and exact-head CI passed on the reviewed bc57544c head, as detailed in section 4.
- No dependency pointer changes occur in this adjacent diff. Top-level pins: trezor crypto 8a392f70a5d5575ece3dfb35f115d4a4b27f497c; protocol dd9c85dc747cf965fb0e7bf49615dc9e7568ee65; Python host 49d537ce953b7524599bfc87f56b7a50a51a13a1; QR 6dfbfdad5d9303ed190d1c3cb7bec34b565b6ce8; SecAES 71d356a1141624994cf613bd2d2583892e8e6d5a; code signing keys a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec. The nested Python protocol and Ethereum list pins are dd9c85dc747cf965fb0e7bf49615dc9e7568ee65 and 89a64f717e1690bb31adb3e4c38e23640357333c.

2. Git line inventory and plain-language changes

The original unit is the single commit 9e6c56c267c6755f55364f2a48073880b4f6f6e4. Immutable inventory commands: git show --format= --numstat --no-renames with that SHA, source repair eeee19feb8d1961176b46e7e6e656be1c550c4e8, and handler tests 1fe4bc71c6882a88e6d40bcfc31a791844c123cf. Counts overlap in two source files and must not be summed into a net diff.

Path	Original +/–	Repair +/–	Behavior and audit result
docs/firmware/reviews/7.15.0-review-round2-remediation.md	3/3	0/0	Updates historical B1, M13, M14 statuses. Source checks below qualify these claims; this document alone is not verification.
lib/firmware/fsm_msg_mayachain.h	0/8	10/0	Original removed the separate Asset screen; repair restores a complete paged denomination disclosure after the amount/recipient screen, with cancellation aborting signing. Net adjacent diff: 5/3.
lib/firmware/fsm_msg_ton.h	5/2	0/0	Formats the blind-sign byte-count prompt into a 48-byte local buffer before confirmation. It continues to disclose the signed byte count and require the AdvancedMode gate inherited from Stack 03.
lib/firmware/fsm_msg_tron.h	15/8	5/15	Original replaced the complete memo pager with one screen or a byte-count summary. Repair calls confirm_bytes on the exact signed memo bytes. Net adjacent diff: 5/8.

Path	Original +/-	Repair +/-	Behavior and audit result
unittests/firmware/CMakeLists.txt	2/1	0/0	Adds existing TRON parser tests to the regular native suite; Bitcoin-only excludes them.
unittests/firmware/mayachain.cpp	0/0	35/0 in review remediation	Direct send-handler cancellation test declines the Asset screen after approving amount/recipient.
unittests/firmware/tron.cpp	0/0	33/0 source repair + 79/3 review remediation	Direct pager test and raw-transaction handler test reject a final memo page, with failure and key-scratch assertions. Net adjacent diff before this report: 112/3.

The net code-predecessor command is `git diff --numstat`

2e008f8527f663107922835dbc8761333b8f073f..1fe4bc71c6882a88e6d40bcfc31a791844c123cf; it includes the prior report source and PDF, the historical remediation note, and the six implementation/test paths above. Its implementation/test counts in table order are 5/3, 5/2, 5/8, 2/1, 35/0, and 112/3. This updated report source and PDF are documentation paths in the final PR diff; their final identity and counts are recorded in the PR body because a file cannot contain its own final commit hash.

3. Current-source reconciliation and security findings

Finding	Sensitive signed state and observer	Path, assertion, falsification, disposition
S04-1, TRON memo tail hidden	raw_data.data memo bytes originate in the host's TronSignTx.raw_tx, are serialized into the signed transaction, and must be disclosed in full to the person on the device before signing. Applies to regular firmware during TRON signing; Bitcoin-only has no TRON handler. A byte-count summary, truncated line, or hidden binary tail is forbidden.	The original adjacent diff used one unpagged confirm for up to 114 printable bytes and only "Data attached (N bytes)" for binary/long memos. The repair calls confirm_bytes on parsed.memo and parsed.memo_len, which escapes and pages all bytes and requires final-page hold. Tron.LongBinaryMemoRequiresApprovalOfEveryPage exercises binary paging; Tron.RejectingFinalMemoPageCancelsSignHandler exercises the parsed raw-data path and final-page refusal through fsm_msgTronSignTx. Both negative paths check cancellation, and the handler test checks cleared key scratch and no leftover approvals. Fixed; 25/25 TRON native tests pass locally.
S04-2, MayaChain asset removed	send.denom/default cacao is the asset serialized into the signing JSON; a person on the device must see it. Applies to regular firmware during MayaChain send signing. The single amount/recipient layout can clip a long denomination; a clipped tail is forbidden.	Original adjacent diff deleted the independent Asset confirmation. The repair calls confirm_bytes("Asset", coin_denom, strlen(coin_denom)) after amount/recipient approval and aborts on refusal. Mayachain.RejectingAssetScreenAbortsSendHandler supplies a 68-character denom to fsm_msgMayachainMsgAck, accepts amount/recipient, rejects Asset, and checks cancelled/aborted state and no leftover approvals. Fixed; 12/12 MayaChain native tests pass locally.

TON's 48-byte buffer fits the literal prompt and a 32-bit unsigned decimal byte count (at most 37 bytes plus NUL), so this formatting change does not truncate the value. The blind-only policy and AdvancedMode gate are inherited, not introduced by this commit. Historical M13's TRON typed-hash gate and M14's enlarged amount buffer are present in the predecessor; the changed status rows are provenance notes, not new Block 04 implementation. B1's ARM link claim is supported here by the full MinSizeRel ARM link; the trezor pointer itself did not change in Block 04. The original "M14 fixed" row does not excuse the separate asset-display regression found above.

4. Verification and artifact identity

Build image: kktech/firmware@sha256:7438e53933d47d53157ed6d96d864cb208597e62dce26235ace09d1063427fa2. The handler tests and 435-test regular firmware rerun use source commit 1fe4bc71c6882a88e6d40bcfc31a791844c123cf; earlier variant builds and CI use source-equivalent firmware with the same implementation and pins but fewer tests, at edf76450b694f30bee21f7293ff3a74ec14b2c46. The new test commit changes no firmware implementation or dependency pointer.

Check	Result	Evidence and limit
Targeted regular native	Pass , 37/37 TRON and MayaChain tests	Pinned Docker emulator build; direct handler tests accept prior screens and decline Asset/final memo page. No physical OLED observation.
Full regular native	Pass , firmware 435/435 at test remediation; board 19/19, crypto 18/18, Zcash crypto 72/72 on prior source-equivalent head	Pinned Docker build; suites run from fresh temporary emulator working directories. A preliminary make xunit from a reused persistent directory failed one recovery test because prior emulator flash remained; the same test and all suites pass in fresh directories.
Bitcoin-only native	Pass , firmware 121/121, board 19/19, crypto 18/18	Pinned Docker emulator build with -DKK_BITCOIN_ONLY=ON; make xunit. TRON and MayaChain tests are intentionally absent in this variant.

Check	Result	Evidence and limit
Full ARM MinSizeRel	Pass , firmware.keepkey.elf linked	Pinned Docker device.cmake, make -j4; local build tree /private/tmp/kk715-stack04-arm. Physical signing and signed-device upgrade remain pending.
Bitcoin-only ARM MinSizeRel	Pass , firmware.keepkey.elf linked	Same command with -DKK_BITCOIN_ONLY=ON; local build tree /private/tmp/kk715-stack04-arm-btc.
Host/emulator signing flows, prior exact-head CI	Pass on reviewed head edf76450b, run 35926958344	Full/Bitcoin-only host, native, ARM, report, evidence and final CI gates passed. Full Python JUnit: 830 tests, 257 skips; Bitcoin-only: 830 tests, 486 skips. Relevant full skips: mixed MayaChain send/deposit ACK and structured TRON transfer/TRC-20 signing. Raw-data TRON and MayaChain signing cases ran. Emulator publication was intentionally skipped. This run predates the handler-test and report remediation.
Reviewed remediation exact-head CI	Pass on bc57544cff4178d0ca46d6b14537750f4131b09a, run 35930492139	Full/Bitcoin-only native, host, ARM, report, evidence and final CI gates passed. The regular native JUnit includes MayaChain 12/12 and TRON 25/25, with zero failures. Full Python JUnit: 830 tests, 257 skips; Bitcoin-only: 830 tests, 486 skips. Relevant full skips are mixed MayaChain ACK cases and structured TRON signing cases; raw-data TRON and MayaChain signing cases ran. Emulator publication was intentionally skipped. This run completed after the report at bc57544c was frozen. The final documentation-head run is recorded in the PR body and main-worktree claim so this report does not claim a future run as complete. Physical OLED/signing and signed-device upgrade remain pending.

The prior run's artifact IDs are: full/Bitcoin-only native 10779174687 / 10779867084; full/Bitcoin-only Python 10779219996 / 10778938820; full/Bitcoin-only ARM 10779921211 / 10779149362; report 10779743042; full/Bitcoin-only OLED 10780085598 / 10779013608. Its ARM manifest set SHA256 is c910adaec2a31b8db1b377499da7b7a68a58402eea98b0d850ada338cc4cd67b. Reviewed remediation run 35930492139 artifacts are: full/Bitcoin-only native 10780873577 / 10780848450; Python 10781271479 / 10781107673; ARM 10780818170 / 10781365764; report 10780749232; OLED 10781136821 / 10780863523. Local build trees are ephemeral artifacts, not reproducible Git inputs. No production device was used in this audit.

Local artifact SHA256: regular firmware unit with handler tests

171fff93e8ac8455c8e8e59bfd54971dd7849e35e2e62c7d3cdec260116d6013; board unit
3caa34c54909f8da3b7f2aa35af6e4c4b054518970b2c7589a8b2068fddc48cf2; crypto unit
52982883650ff3386430168d0ec915442672e9c75cfc5e194a2277f4ea187fe9; Zcash crypto unit
98983e4b6890b3b07e60cf6c18addb3340cff0c6305614a252cc89acab7c058d; Bitcoin-only firmware unit
993e35ab015117211bb8ca597555aa45150ca755146f2849a68547a73f5fa4cc; regular ARM ELF
37640d6471ea5d3a729574b5047c2fe547ebb9b2917cd9c35def75b43641d867; Bitcoin-only ARM ELF
4004cbe932df1bfb052159f86d3036766d5ffe52beedce03ab40fe6473880b6d.

5. Render, local preflight and review checkpoint

This Markdown is the source report; the matching PDF is 715-04-review-20260923.pdf. All three rendered pages were opened and checked after this remediation. Live PR base/head, final adjacent diff inventory, `git diff --check`, and the main worktree's `scripts/release/check-code-review-diff.sh` must be rechecked after the report files are frozen. The PR remains code-bearing.

Status by gate: implementation **done and pushed**; targeted verification **passed**; native, ARM, and host integration **passed on reviewed head** bc57544c; adversarial display contract **handler rejection paths executed**; external reviews 5297522809 and 5297798874 **delivered, both Changes recommended**. Their five findings were corrected with pushed-commit replies and resolved threads. Review 5297905614 later identified stale status wording about the second review; this revision records its completed reply and resolution. The current review checkpoint, request count, and final documentation-head CI are tracked in the PR body and main-worktree claim because those facts change after a report is frozen. Predecessor and release acceptance remain pending.